

Final ISO 27001 Compliance Verification

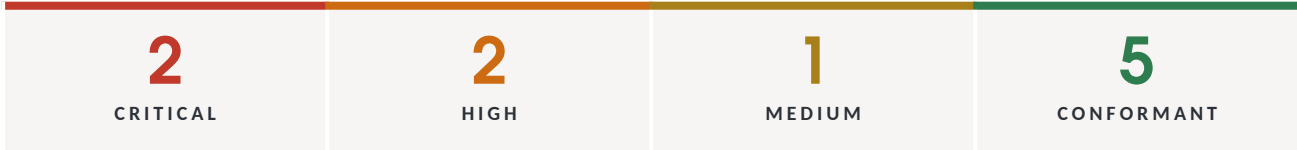
A consolidated verification of NovaTech Managed Services against ISO/IEC 27001:2022 Annex A, PIPEDA Principle 7, and Canadian Centre for Cyber Security baseline guidance.

SUBJECT ORGANIZATION	NovaTech Managed Services (simulated engagement)
COURSE	420-B04-VA — Conformity Assessment
PREPARED BY	Marco Helie
REPORT DATE	June 2026

CONTENTS

01	Executive Summary
02	Scope & Methodology
03	Summary of Key Findings
04	Evidence Review
05	Risk Analysis
06	Remediation Roadmap
07	Final Recommendations
08	Conclusion
09	References
10	Appendices

ASSESSMENT AT A GLANCE



Five non-conformities and five areas of conformity were identified across network security, access control, cryptography, logging and incident response.

01 Executive Summary

This report presents the final ISO 27001 compliance verification for NovaTech Managed Services, a Canadian IT services provider managing infrastructure for approximately 40 small-to-medium business clients across North America. The assessment was conducted across two phases, evaluating NovaTech's network security, access controls, cryptographic practices, logging and monitoring capabilities, and incident response readiness against ISO 27001:2022 Annex A controls, PIPEDA Principle 7, and Canadian Centre for Cyber Security (CCCS) baseline guidance.

The assessment identified five areas of non-conformity. Two are rated Critical: unrestricted inbound firewall rules on management ports (A.13.1.1) and absence of multi-factor authentication on privileged domain administrator accounts (A.9.4.2). Two are rated High: continued use of the deprecated TLS 1.0 protocol on internal services (A.10.1.1) and incomplete SIEM integration leaving Linux and cloud systems unmonitored (A.12.4.1). One is rated Medium: an untested incident response plan that exists in draft form but has never been exercised (A.16.1.1).

The assessment also identified several areas of conformity, including compliant password policies, properly configured account lockout thresholds, and the presence of a deployed SIEM platform and perimeter firewall infrastructure.

NovaTech's primary challenge is not the absence of security controls but the gap between implementation and operational effectiveness. Controls exist but are inconsistently enforced, monitored, and reviewed. The remediation roadmap in this report prioritizes the two Critical findings for immediate action (within 14 days), followed by High-priority items over 30 to 90 days, and Medium-priority governance improvements within 120 days. Sustained compliance will require establishing formal change management, periodic configuration reviews, and an annual audit cycle.

02 Scope & Methodology

2.1 Organizational Context

NovaTech Managed Services provides infrastructure management, cloud hosting, and technical support to SMB clients. The company operates a hybrid environment consisting of on-premise Windows and Linux servers, Fortinet perimeter firewalls, a Wazuh SIEM deployment, and cloud workloads hosted on AWS and Azure for select clients. NovaTech handles sensitive client data including financial records, employee information, and in some cases protected health information on behalf of healthcare clients.

2.2 Systems Assessed

- Windows Server 2022 Active Directory domain controllers
- Ubuntu 22.04 LTS application servers
- Fortinet FortiGate perimeter firewall
- Wazuh SIEM deployment
- Internal Windows file servers
- Legacy Cisco VPN concentrator

2.3 Assessment Methodology

The verification was conducted across two phases using a combination of automated and manual methods:

- **Phase 1 (Deliverable C):** Baseline compliance assessment using CIS-CAT Pro and Nessus scans, policy review against ISO 27001 Annex A controls, and identification of compliance gaps across six policy domains.

- **Phase 2 (Deliverable E):** Refined analysis of the three highest-risk findings, with detailed evidence collection, risk ratings, and SMART recommendations. Cross-referenced with PIPEDA and CCCS standards.
- **This final report (Phase 3):** Consolidation of all findings, expanded risk analysis to five items, addition of conformity areas, comprehensive evidence review, and development of a phased remediation roadmap with future-proofing recommendations.

2.4 Frameworks Applied

FRAMEWORK	ROLE IN ASSESSMENT
ISO 27001:2022	Primary compliance standard — Annex A controls used as the assessment baseline
CIS Benchmarks	Technical configuration standards for automated scanning (Windows Server 2022, Ubuntu 22.04)
PIPEDA	Canadian federal privacy legislation — Principle 7 (Safeguards) requires appropriate technical and organizational security measures
CCCS Top 10	Canadian Centre for Cyber Security baseline security actions — used to validate findings against national guidance
NIST SP 800-53	Supplementary reference for granular control mapping where ISO 27001 Annex A controls require technical specificity

03 Summary of Key Findings

3.1 Areas of Non-Conformity

#	FINDING	ISO 27001 CONTROL	SEVERITY	STATUS
NC-1	Unrestricted inbound firewall rules on ports 21, 23, 3389	A.13.1.1 — Network Controls	CRITICAL	Non-Conformant
NC-2	No MFA on privileged domain administrator accounts	A.9.4.2 — Secure Log-on Procedures	CRITICAL	Non-Conformant
NC-3	TLS 1.0 enabled on internal file servers and VPN	A.10.1.1 — Cryptographic Controls Policy	HIGH	Non-Conformant
NC-4	Incomplete SIEM integration (Linux / cloud not covered)	A.12.4.1 — Event Logging	HIGH	Partially Conformant
NC-5	Incident response plan drafted but never tested	A.16.1.1 — Incident Management Planning	MEDIUM	Partially Conformant

3.2 Areas of Conformity

#	CONTROL AREA	ISO 27001 CONTROL	STATUS	EVIDENCE
C-1	Password policy meets CIS Benchmark requirements	A.9.4.3 — Password Management	Conformant	GPO enforces 12-character minimum, complexity requirements enabled
C-2	Account lockout threshold properly configured	A.9.4.2 — Secure Log-on (partial)	Conformant	Lockout after 5 failed attempts verified in AD GPO
C-3	Perimeter firewall deployed and operational	A.13.1.1 — Network Controls (partial)	Conformant	Fortinet FortiGate active at network perimeter with default-deny outbound
C-4	SIEM platform deployed	A.12.4.1 — Event Logging (partial)	Conformant	Wazuh operational, ingesting firewall and Windows Event Logs
C-5	Role-based access control via Active Directory	A.9.2.3 — Management of Privileged Access	Conformant	AD security groups mapped to organizational roles

NovaTech has foundational security controls in place. The non-conformity findings reflect gaps in enforcement, coverage, and review processes rather than a complete absence of security infrastructure.

04 Evidence Review

This section describes the evidence collected during the assessment and explains how each piece supports or fails to support compliance claims.

4.1 Firewall Rule Export (Appendix A)

A manual export of the Fortinet FortiGate firewall rule set was reviewed. Three rules were identified with source set to "Any" and action set to "Accept" on ports 21 (FTP), 23 (Telnet), and 3389 (RDP). The rules were created between March

2023 and January 2024 and have no associated expiration dates, no documented justification, and no change management tickets.

This evidence directly demonstrates non-conformity with A.13.1.1, which requires network connections and traffic flows to be controlled based on security requirements. The rules appear to be temporary exceptions that were never revoked, a pattern consistent with the absence of a formal change management process for firewall modifications.

4.2 Active Directory GPO Settings (Appendix B)

A review of Active Directory Group Policy Objects confirmed that no conditional access policy or MFA requirement is configured for accounts in the Domain Admins, Enterprise Admins, or Schema Admins security groups. Authentication logs from the domain controllers show that privileged account logins consistently use single-factor (password only) authentication. This evidence supports the NC-2 finding. However, the same GPO review confirmed that password policies (12-character minimum, complexity enabled) and account lockout settings (5 attempts) meet CIS Benchmark requirements, supporting conformity findings C-1 and C-2.

4.3 Nessus Scan Results (Appendix C)

Nessus vulnerability and configuration scans flagged TLS 1.0 as enabled on three internal file servers (ports 445) and one legacy VPN concentrator (port 443). The scan output confirms that these services accept TLS 1.0 connections alongside TLS 1.2, rather than enforcing TLS 1.2 as a minimum. This evidence supports NC-3. TLS 1.0 was deprecated by RFC 8996 in March 2021 and is vulnerable to known attacks including POODLE and BEAST.

4.4 Wazuh SIEM Configuration Review

A review of the Wazuh SIEM deployment confirmed that the platform is operational and ingesting logs from the Fortinet firewall and Windows domain controllers. However, no Wazuh agents are deployed on Ubuntu application servers, and cloud workloads on AWS and Azure are not forwarding audit logs to the SIEM. This means security events on Linux systems and cloud infrastructure go unmonitored, creating detection blind spots. This evidence supports NC-4 while also confirming partial conformity (C-4) for the systems that are integrated.

4.5 Incident Response Plan Review

A draft incident response plan was located on NovaTech's internal documentation repository. The document outlines general response phases (identification, containment, eradication, recovery) but does not define specific escalation paths, notification timelines, or roles and responsibilities. No tabletop exercises or simulation tests have been conducted, and no post-incident review documentation exists. This evidence supports NC-5 — the IRP exists on paper but has never been validated in practice, which means its effectiveness during an actual incident is unknown.

05 Risk Analysis

5.1 Risk Matrix

ID	RISK DESCRIPTION	LIKELIHOOD	IMPACT	SCORE	SEVERITY
R1	Exploitation of open firewall ports leading to unauthorized internal access	5 — Almost Certain	5 — Severe	25	CRITICAL
R2	Credential-based compromise of domain admin accounts due to missing MFA	4 — Likely	5 — Severe	20	CRITICAL
R3	Data interception via deprecated TLS 1.0 on internal services	3 — Possible	4 — Major	12	MEDIUM
R4	Undetected breach due to incomplete SIEM coverage on Linux / cloud systems	3 — Possible	4 — Major	12	MEDIUM
R5	Delayed or ineffective incident response due to untested IRP	2 — Unlikely	4 — Major	8	MEDIUM

5.2 Risk Heat Map

See Appendix E: Risk Heat Map.

5.3 Business Impact Analysis

R1 — Open Firewall Ports: These ports are internet-facing and discoverable by automated scanning tools within hours. FTP and Telnet transmit credentials in plaintext. RDP is the most commonly exploited protocol for ransomware delivery. Because NovaTech manages client infrastructure, a compromise through these ports could cascade across multiple client environments, triggering contractual liability, regulatory investigation under PIPEDA, and catastrophic reputational damage.

R2 — No MFA on Admin Accounts: Domain administrator accounts have unrestricted control over the entire Windows environment. A single successful phishing attack targeting an admin account would give an attacker the ability to access, modify, or encrypt data across all client systems. The CCCS identifies MFA as its second-highest priority security action because credential-based attacks remain the most frequent initial access method in Canadian organizations.

R3 — TLS 1.0: While exploitation requires a man-in-the-middle position, the impact is significant: interception of file transfers containing client data or capture of VPN credentials. The use of a deprecated protocol would also be flagged immediately in any formal ISO 27001 certification audit.

R4 — Incomplete SIEM: Without log coverage on Linux and cloud systems, breaches affecting those platforms can persist undetected for extended periods. Industry data consistently shows that longer dwell times lead to significantly higher breach costs. NovaTech's current SIEM coverage creates a false sense of security — the monitored systems appear clean while unmonitored systems may already be compromised.

R5 — Untested IRP: An incident response plan that has never been tested may fail under the pressure of an actual breach. Staff may not know their roles, escalation paths may be unclear, and notification timelines may be missed. Both PIPEDA and ISO 27001 expect organizations to demonstrate that their response capabilities are operational, not merely documented.

06 Remediation Roadmap

6.1 Short-Term (0-30 Days)

PRIORITY	ACTION	RESPONSIBLE	TIMELINE
CRITICAL	Audit all firewall rules; disable / remove rules permitting inbound traffic on ports 21, 23, 3389 from unrestricted sources	Network Administrator	Day 1
CRITICAL	Implement formal change management policy for firewall exceptions (requiring justification, expiration date, assigned owner)	IT Security Lead	Within 14 days
CRITICAL	Deploy MFA for all Domain Admin, Enterprise Admin, and Schema Admin accounts using Azure AD conditional access or Duo Security	IT Security Lead	Within 14 days
HIGH	Disable TLS 1.0 and TLS 1.1 on all Windows file servers via Group Policy (SChannel registry settings)	System Administrator	Within 14 days
HIGH	Assess legacy VPN concentrator for TLS 1.2 support; schedule firmware upgrade or replacement	Network Administrator	Within 30 days

6.2 Medium-Term (30-90 Days)

PRIORITY	ACTION	RESPONSIBLE	TIMELINE
HIGH	Deploy Wazuh agents on all Ubuntu application servers	SOC Analyst / IT Security	Within 45 days
HIGH	Configure cloud audit log forwarding from AWS CloudTrail and Azure Activity Log to Wazuh	SOC Analyst	Within 60 days
HIGH	Establish documented daily log review procedures for SIEM alerts	IT Security Lead	Within 60 days
HIGH	Extend MFA to all user accounts (not just privileged)	IT Security Lead	Within 90 days
MEDIUM	Conduct quarterly access reviews — managers verify team permissions are appropriate	IT Security, Department Managers	First review within 90 days

6.3 Long-Term (90-120+ Days)

PRIORITY	ACTION	RESPONSIBLE	TIMELINE
MEDIUM	Finalize incident response plan with specific escalation paths, notification timelines (PIPEDA requirements), roles, and evidence preservation procedures	IT Security Lead, Legal	Within 90 days
MEDIUM	Conduct tabletop exercise simulating a ransomware scenario affecting client data	IT Security, Legal, Executive Leadership	Within 120 days
MEDIUM	Perform comprehensive internal compliance audit against ISO 27001 Annex A controls	Internal Audit or External QSA	Within 120 days

PRIORITY	ACTION	RESPONSIBLE	TIMELINE
MEDIUM	Establish annual compliance review cycle and maintain a living risk register	IT Security Lead	Ongoing
LOW	Implement network segmentation (VLANs) to isolate client environments from each other and from the management network	Network Administrator	6-month target

07 Final Recommendations

7.1 Governance and Process Maturity

NovaTech's findings reveal a pattern: security tools are deployed but governance processes are missing. Firewalls exist without change management. SIEM is running without complete log coverage. An IRP is drafted without testing. To sustain compliance beyond the initial remediation, NovaTech must establish three foundational governance processes:

- **Change Management:** Every modification to firewall rules, access policies, or server configurations must go through a formal review and approval process with documented justification. Temporary exceptions must include an expiration date and an assigned owner.
- **Periodic Review:** Configuration compliance reports should be generated monthly, comparing current system states against CIS baselines. Access reviews should be conducted quarterly. Security policies should be reviewed semi-annually.
- **Annual Audit Cycle:** An internal audit against ISO 27001 Annex A controls should be conducted annually by personnel independent of the teams responsible for the controls being assessed (ISO 27001 Clause 9.2). Audit findings should feed directly into the risk register and remediation planning.

7.2 Ongoing Monitoring

- SIEM coverage must be treated as a living requirement. As NovaTech onboards new clients or deploys new infrastructure, log sources must be integrated into Wazuh as part of the provisioning process, not as an afterthought.
- Automated vulnerability scanning (Nessus or Qualys) should run weekly, with critical findings escalated within 24 hours and tracked to remediation.
- Cloud-native security tools (AWS Config Rules, Azure Policy) should be deployed to enforce compliance baselines at the infrastructure layer for cloud-hosted client environments.

7.3 Future Compliance Considerations

- If NovaTech pursues formal ISO 27001 certification, the organization should engage a certification body for a Stage 1 (documentation review) audit within 6 months of completing the remediation roadmap, followed by a Stage 2 (evidence and implementation) audit.
- NovaTech should evaluate whether any of its processing activities trigger PIPEDA breach reporting requirements under the Breach of Security Safeguards Regulations, and ensure its IRP includes the mandatory notification to the Office of the Privacy Commissioner of Canada.
- As NovaTech expands its client base, particularly if serving clients with regulatory obligations (healthcare, financial services), the organization should assess whether additional frameworks (SOC 2, HIPAA) are necessary to meet contractual requirements.

08 Conclusion

This final compliance verification report consolidates two phases of assessment into a comprehensive evaluation of NovaTech Managed Services' security posture against ISO 27001, PIPEDA, and CCCS standards.

The assessment identified five areas of non-conformity and five areas of conformity. NovaTech has foundational security infrastructure in place — a perimeter firewall, a SIEM platform, role-based access control, and compliant password policies. However, the organization lacks the enforcement, monitoring, and governance processes needed to ensure these controls remain effective over time. The most critical gaps — open firewall ports and missing MFA on admin accounts — represent immediate, exploitable risks that must be remediated within 14 days.

The remediation roadmap provides a structured path from immediate risk reduction through medium-term hardening to long-term governance maturity. The final recommendations emphasize that compliance is a continuous cycle, not a project with an end date. Change management, periodic review, and annual auditing are the processes that will prevent the findings in this report from recurring.

NovaTech is not currently ready for ISO 27001 certification, but with disciplined execution of the remediation roadmap and establishment of the governance processes recommended in this report, the organization can achieve a compliant and sustainable security posture within 6 to 12 months.

09 References

- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 — Information security management systems — Requirements*.
<https://www.iso.org/standard/27001>
- Center for Internet Security. (n.d.). *CIS Benchmarks*. Retrieved June 2026.
<https://www.cisecurity.org/cis-benchmarks>
- Office of the Privacy Commissioner of Canada. (n.d.). *PIPEDA in brief*. Retrieved June 2026.
https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/pipeda_brief/
- Canadian Centre for Cyber Security. (n.d.). *Top 10 IT Security Actions*. Retrieved June 2026.
<https://www.cyber.gc.ca/en/guidance/top-10-it-security-actions>
- National Institute of Standards and Technology. (2020). *NIST Special Publication 800-53 Revision 5*.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- IT Governance Ltd. (n.d.). *Free ISO 27001 Resources*. Retrieved June 2026.
<https://www.itgovernance.co.uk/blog/the-only-free-iso-27001-resources-you-will-ever-need>
- FIRST.org. (n.d.). *Common Vulnerability Scoring System (CVSS)*. Retrieved June 2026.
<https://www.first.org/cvss/>

10 Appendices

Appendix A — Firewall Rule Export

RULE ID	SOURCE	DESTINATION	PORT	PROTOCOL	ACTION	CREATED	EXPIRY
FW-0047	Any	10.0.1.15	21	TCP	Accept	2023-03-12	None
FW-0063	Any	10.0.1.22	23	TCP	Accept	2023-08-05	None
FW-0091	Any	10.0.2.10	3389	TCP	Accept	2024-01-19	None

Note: All three rules have source set to "Any" (unrestricted) and no expiration date. No change management tickets were found associated with these rules.

Appendix B — Active Directory GPO Authentication Settings

SETTING	VALUE	EXPECTED VALUE
Require MFA for Domain Admins	Not Configured	Enabled
Require MFA for Enterprise Admins	Not Configured	Enabled
Require MFA for Remote Desktop	Not Configured	Enabled
Account Lockout Threshold	5 attempts	5 attempts (compliant)
Password Minimum Length	12 characters	12 characters (compliant)

Note: MFA-related policies are not configured for any privileged security group. Password and lockout policies meet CIS Benchmark requirements.

Appendix C — Nessus Scan Results: TLS 1.0 Detection

HOST	PORT	FINDING	SEVERITY	PROTOCOLS DETECTED
10.0.3.5 (FileServer01)	445	TLS 1.0 Enabled	HIGH	TLS 1.0, TLS 1.1, TLS 1.2
10.0.3.6 (FileServer02)	445	TLS 1.0 Enabled	HIGH	TLS 1.0, TLS 1.1, TLS 1.2
10.0.3.7 (FileServer03)	445	TLS 1.0 Enabled	HIGH	TLS 1.0, TLS 1.2
10.0.4.1 (VPN-Legacy)	443	TLS 1.0 Enabled	HIGH	TLS 1.0, TLS 1.2

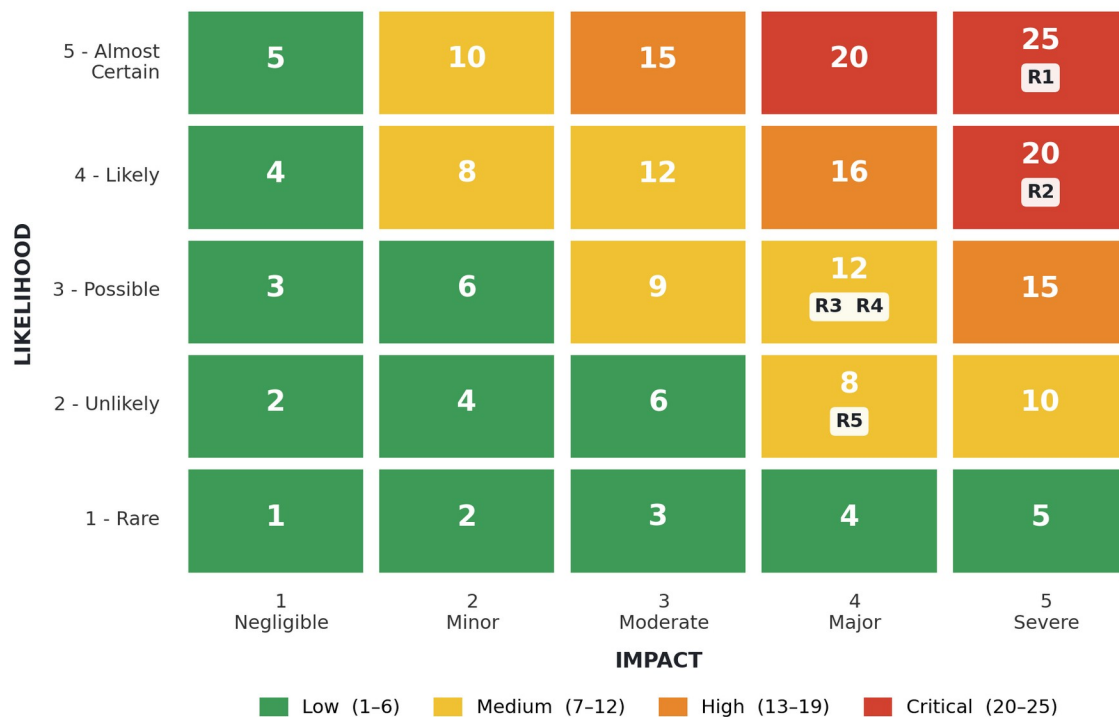
Note: All four hosts accept TLS 1.0 connections. TLS 1.0 was deprecated in RFC 8996 (March 2021).

Appendix D — Wazuh SIEM Coverage Summary

SYSTEM	LOG SOURCE	INTEGRATED	STATUS
Fortinet FortiGate	Firewall logs	Yes	Active
Windows Server 2022 (DCs)	Windows Event Logs	Yes	Active
Ubuntu 22.04 (App Servers)	Syslog	No	Not deployed
AWS Workloads	CloudTrail	No	Not configured
Azure Workloads	Activity Log	No	Not configured
VPN Concentrator	Auth logs	No	Not configured

Note: Only 2 of 6 log source categories are integrated into the SIEM. Linux, cloud, and VPN logs are not monitored.

Appendix E — Risk Heat Map



Compliance risk heat map — likelihood × impact, with R1-R5 plotted